

Escaneo de imágenes de contenedores en el pipeline

Botero, Santiago. Perilla, Laura Natalia. Rodríguez, Daniel Esteban

Escuela Colombiana de Ingeniería Julio Garavito

{santiago.botero-g,laura.perilla-q,daniel.rsuares}@mail.escuelaing.edu.co

Resumen—Este documento analiza la evolución reciente del escaneo de imágenes de contenedores como control de seguridad dentro del pipeline CI/CD en entornos DevSecOps. Se examinan las metodologías de detección de vulnerabilidades aplicadas a capas de contenedor, las herramientas especializadas más relevantes del ecosistema industrial, y su integración en flujos de entrega continua. Asimismo, se discuten los principales retos técnicos que enfrenta esta práctica y las mejores estrategias para maximizar su efectividad. El estudio propone un enfoque integral que combina automatización, priorización contextual de riesgos y validación continua dentro de una arquitectura DevSecOps resiliente.

Index Terms—DevSecOps, Arquitectura de Software Segura, Seguridad en Contenedores, Container Image Scanning, SBOM, CI/CD, Kubernetes, Red Team, Blue Team, NIST SSDF, OWASP, ISO/IEC 27001, MITRE ATT&CK, SLSA, Vulnerability Management

I. INTRODUCCIÓN

El escaneo de imágenes de contenedores constituye un componente crítico dentro del pipeline de desarrollo DevSecOps, ya que permite identificar vulnerabilidades conocidas, paquetes desactualizados y configuraciones de capas inseguras antes del despliegue en entornos productivos. En arquitecturas cloud-native, donde Docker y Kubernetes se emplean ampliamente para la orquestación de microservicios, las imágenes de contenedores representan un vector significativo de riesgo si no son analizadas sistemáticamente en cada etapa del ciclo de vida del software [4].

La evolución del enfoque DevSecOps ha impulsado la integración de controles automáticos de escaneo en los pipelines CI/CD [2]. Sin embargo, estudios recientes evidencian brechas en los mecanismos de correlación de vulnerabilidades que pueden afectar la precisión y confiabilidad de la gestión de riesgos en contenedores [1], [3]. En este contexto, el escaneo de imágenes no solo cumple una función técnica, sino también estratégica, dentro de una postura de seguridad continua.

II. METODOLOGÍAS DE ESCANEAMIENTO EN EL PIPELINE DEVSECOPS

El escaneo de imágenes de contenedores dentro del pipeline CI/CD se basa en metodologías automatizadas que analizan las capas del contenedor, las dependencias del sistema operativo base y los paquetes incluidos en tiempo de construcción (build time). Estas metodologías pueden clasificarse en tres categorías principales:

1. **Escaneo estático de vulnerabilidades (Vulnerability Scanning):** analiza bases de datos CVE y compara versiones de paquetes con vulnerabilidades conocidas.

2. **Análisis basado en SBOM:** genera un inventario detallado de componentes y lo correlaciona con fuentes de inteligencia de amenazas [1], [3]
3. **Evaluación de políticas y cumplimiento:** valida configuraciones inseguras y prácticas de hardening antes de permitir el despliegue en registros o clústeres.

La integración típica en un pipeline DevSecOps implica la ejecución del escaneo tras la construcción de la imagen (*build*) y antes de su publicación en el registry. Si se detectan vulnerabilidades críticas, el pipeline puede bloquear automáticamente la entrega (*fail build*), aplicando el principio de seguridad como código [2]. Esta ubicación estratégica en el pipeline garantiza que ninguna imagen con vulnerabilidades conocidas de alta severidad alcance entornos de staging o producción sin revisión explícita.

III. HERRAMIENTAS DE ESCANEAMIENTO EN EL PIPELINE DEVSECOPS

El ecosistema industrial ha desarrollado múltiples herramientas especializadas en el escaneo de imágenes de contenedores, tanto de código abierto como comerciales. Entre las más relevantes se encuentran Trivy, Gype, Clair, Anchore, Snyk, Prisma Cloud y Aqua Security, destacadas en análisis comparativos recientes [4], [5].

Estas herramientas ofrecen capacidades como:

- Detección de vulnerabilidades en capas base (Alpine, Debian, Ubuntu).
- Escaneo de dependencias de aplicaciones (Node.js, Python, Java, Go).
- Generación automática de SBOM en formatos estandarizados, como subproducto del escaneo.
- Integración nativa con GitHub Actions, GitLab CI, Azure DevOps y Jenkins.

Por ejemplo, plataformas comerciales como Snyk integran análisis de vulnerabilidades de contenedores y cargas de trabajo Kubernetes dentro de un enfoque unificado de gestión de riesgo [6]. Asimismo, reportes industriales de 2025 resaltan la importancia de herramientas capaces de correlacionar vulnerabilidades con el contexto de ejecución, reduciendo falsos positivos y priorizando riesgos reales [5].

La tendencia actual apunta hacia la consolidación de plataformas CNAPP (Cloud-Native Application Protection Platforms), que combinan escaneo de imágenes y monitoreo en runtime [4], [5].

IV. MEJORES PRÁCTICAS EN EL ESCANEAMIENTO DE IMÁGENES

Para maximizar la efectividad del escaneo de imágenes en el pipeline DevSecOps, se recomiendan las siguientes prácticas:

1. Integrar el escaneo en cada commit o pull request, evitando análisis únicamente previos al despliegue.
2. Aplicar políticas de bloqueo automático ante vulnerabilidades críticas.
3. Utilizar imágenes base mínimas y actualizadas para reducir superficie de ataque.
4. Correlacionar resultados del escaneo con estándares de seguridad y controles normativos [1].

La literatura reciente enfatiza que la gestión efectiva de vulnerabilidades requiere no solo detectar fallos, sino también priorizarlos según contexto operativo y criticidad del activo [3].

V. EJEMPLO PRÁCTICO: IMPLEMENTACIÓN DE PIPELINE CI/CD CON ANÁLISIS DE VULNERABILIDADES

Como parte de un ejercicio práctico de integración de controles de seguridad en el pipeline DevSecOps, se seleccionó un proyecto de desarrollo de software concurrente para implementar análisis y escaneo de vulnerabilidades de imágenes de contenedores en sus pipelines de CI/CD. El proyecto en cuestión, denominado SmarTrip, consiste en una plataforma social de turismo inteligente con arquitectura microservicios basada en contenedores.

Para este ejercicio, se configuraron pipelines automatizados en GitHub Actions para los cuatro repositorios principales del proyecto, incorporando análisis de vulnerabilidades como puerta de calidad (quality gate) obligatoria antes del despliegue. La implementación se estructuró de la siguiente manera:

V-A. Configuración de Pipelines de Seguridad

Se establecieron pipelines específicos en cada repositorio que ejecutan múltiples herramientas de escaneo en paralelo:

- **Trivy:** Escaneo completo de vulnerabilidades en imágenes de contenedor
- **Grype:** Análisis de vulnerabilidades en capas del sistema operativo
- **CodeQL:** Análisis estático de código fuente para detección de vulnerabilidades
- **SBOM Generation:** Generación automática de Software Bill of Materials

V-B. Umbrales de Seguridad y Políticas de Bloqueo

Los pipelines implementaron políticas de seguridad basadas en umbrales de severidad según el estándar CVSS (Common Vulnerability Scoring System):

Severidad	Puntuación CVSS	Acción en Pipeline
Crítica	9.0-10.0	Bloqueo inmediato del pipeline
Alta	7.0-8.9	Bloqueo con excepción documentada
Media	4.0-6.9	Advertencia y registro en dashboard
Baja	0.1-3.9	Registro informativo únicamente

Cuadro I

UMBRALES DE SEGURIDAD IMPLEMENTADOS EN EL PIPELINE CI/CD

V-C. Integración con GitHub Actions

La configuración del pipeline en GitHub Actions sigue el siguiente flujo:

1. **Trigger:** Se activa en cada push a ramas principales y pull requests
2. **Build Phase:** Construcción de imágenes Docker para cada microservicio
3. **Security Scan:** Ejecución paralela de herramientas de análisis
4. **Policy Evaluation:** Evaluación de resultados contra umbrales configurados
5. **Quality Gate:** Aprobación o bloqueo basado en políticas de seguridad
6. **Registry Push:** Publicación de imágenes solo si pasan los controles de seguridad

VI. RETOS ACTUALES

A pesar de la madurez creciente de las herramientas, el escaneo de imágenes enfrenta desafíos significativos. Entre los más relevantes se encuentran:

- Falsos positivos y discrepancias entre bases de datos de vulnerabilidades [1], [3].
- Dificultad para correlacionar vulnerabilidades con exposición real en tiempo de ejecución.

Estos retos evidencian que el escaneo de imágenes debe integrarse dentro de un enfoque más amplio de seguridad continua, combinando análisis estático con monitoreo dinámico y control de políticas.

VII. CONCLUSIONES

El escaneo de imágenes de contenedores es un pilar fundamental del pipeline DevSecOps moderno, ya que permite prevenir la propagación de vulnerabilidades en entornos cloud-native antes de su despliegue. Su posición estratégica al final del proceso de construcción lo convierte en una barrera de verificación sobre el artefacto real que será ejecutado, complementando los controles aplicados en etapas anteriores del ciclo de vida del software.

Las herramientas actuales ofrecen integración avanzada con CI/CD y capacidades de análisis contextual, pero su efectividad depende de una estrategia integral que combine automatización, políticas de seguridad como código y validación continua [2], [5], [6]. En consecuencia, el escaneo de imágenes no debe considerarse una actividad aislada, sino un mecanismo estratégico dentro de una arquitectura DevSecOps segura y resiliente.

REFERENCIAS

- [1] C. Wang et al., "A Large Scale Empirical Analysis on the Adherence Gap between Standards and Tools in SBOM," ACM Transactions on Software Engineering and Methodology, Jan. 2026, doi: 10.1145/3788692.
- [2] J. Perez, "DevSecOps Empresarial: del SDLC Seguro a la Seguridad de la Cadena de Suministro (SLSA, SBOM, IaC)," Quantum Secure Labs, Nov. 10, 2025. <https://qsecure.es/devsecops-empresas-sdlc-slsa-sbom-iac-soc-xdr/>
- [3] L. Zhou, M. Dacier, and C. Konstantinou, "A reality check on SBOM-based vulnerability management: an empirical study and a path forward," arXiv.org, Nov. 25, 2025. <https://arxiv.org/abs/2511.20313>

- [4] R. Camerlynck, "Top 13 container scanning tools in 2026," Aikido Security, Jul. 18, 2025. <https://es.aikido.dev/blog/top-container-scanning-tools>
- [5] SentinelOne, "10 herramientas de análisis de vulnerabilidades de contenedores en 2025," SentinelOne, Oct. 23, 2025. <https://www.sentinelone.com/es/cybersecurity-101/cybersecurity/container-vulnerability-scanning-tools/>
- [6] Snyk, "Gestión de vulnerabilidades de contenedores y seguridad para cargas de trabajo en Kubernetes | Snyk," Snyk. <https://snyk.io/es/product/container-vulnerability-management/>

AUTORES

Santiago Botero es estudiante de Ingeniería de Sistemas en la Escuela Colombiana de Ingeniería Julio Garavito. Sus áreas de interés incluyen arquitectura de software, sistemas distribuidos, DevSecOps y el desarrollo de soluciones tecnológicas orientadas a la optimización y seguridad de procesos empresariales.

Natalia Perilla es estudiante de octavo semestre de Ingeniería de Sistemas. Sus intereses se enfocan en el desarrollo de software, la ciberseguridad y la computación en la nube, con conocimientos en plataformas como Microsoft Azure y AWS. Actualmente fortalece competencias en diseño e implementación de soluciones tecnológicas orientadas a necesidades reales.

Daniel Rodríguez estudiante de octavo semestre de Ingeniería de Sistemas en la Escuela Colombiana de Ingeniería Julio Garavito. Tiene interés en el área de ciberseguridad, especialmente en la protección de la información y el análisis de vulnerabilidades. Se destaca por su enfoque analítico y su capacidad para la resolución estructurada de problemas, aplicando pensamiento lógico y buenas prácticas en el desarrollo de soluciones tecnológicas.